SLIIT UNI
THE KNOWLEDGE UNIVERSITY

Faculty of Computing



IE3122: Network Security

Year 3 Semester 1 (2026)

Northbridge Savings & Finance Network Security Upgrade

Project Report

Student ID: IT24103547
Student Name: Oshadi J.A.A

23.9.2026

- **Contribution Overview**

Section	Member 4 responsibility
1	Threat 1 - Online Banking Portal Compromise
2	Threat 2 - Insider / Stolen Account Privilege Abuse
3	Technology Proposal **A - OpenVPN Access Server**
4	Technology Proposal **B - FreeRADIUS**
5	Technology Proposal **C - OPNsense Multi-Firewall / Segmented Architecture**
6	Technology Proposal **D - Suricata IDS/IPS**
7	**Hardening Configuration 1** - Cisco Zone-Based Firewall
8	**Hardening Configuration 2** - STP PortFast + BPDU Guard

1. Individual Threat Model – T1

Online Banking Portal Compromise

Scenario focus:

Northbridge operates a public online banking service that processes sensitive customer and financial information. The assignment scenario also identifies weaknesses including the absence of a dedicated firewall/IDS/IPS, no formal patch management process, and no centralized logging.

Threat model element	Member 4 analysis
Asset	Online banking infrastructure, the public banking portal, customer financial, personal data, and customer account services.
Vulnerability	The internet facing banking environment has inadequate protective and monitoring controls. The scenario identifies no dedicated firewall or IDS/IPS, no formal patch management process, and no centralized logging. A specific application flaw is not established by the scenario, so this model treats an exploitable flaw in the exposed service as a potential weakness rather than a confirmed SQL-injection or other named vulnerability.
Threat	An external cyber attacker targeting Northbridge's public online banking service.
Exploit	The attacker identifies and exploits a vulnerability in the exposed banking service or a supporting component that is not adequately prevented, patched, or detected.
Attack	Successful compromise of the public-facing banking service or server, enabling unauthorized access and potentially creating a foothold into other systems.
Impact	Possible disclosure or modification of customer financial or personal data, fraudulent activity, service disruption, investigation and recovery costs, regulatory consequences, and reputational damage.
Risk	Critical. The service is publicly exposed and handles high value financial assets. The potential impact is severe, while the scenario also identifies gaps in firewalling, intrusion prevention, patch management, and centralized logging. The final impact score should be aligned with the group's common risk matrix.

2. Individual Threat Model – T2

Insider/Stolen acount privilege abuse

Scenario focus:

Northbridge currently relies on local account practices, while the scenario notes password reuse and the absence of centralized authentication and centralized logging.

Threat model element	Member 4 analysis
Asset	Core banking systems, customer information, staff credentials, and other sensitive internal systems.
Vulnerability	Local accounts, password reuse, lack of centralized AAA, and insufficient centralized auditing reduce access control consistency and accountability.
Threat	A malicious insider, or an external attacker who obtains legitimate, stolen, or shared staff credentials.
Exploit	The actor abuses valid credentials and weakly controlled account access to obtain unauthorized access or perform actions that may be difficult to attribute reliably.
Attack	Unauthorized access to banking systems or data using a legitimate, shared, stolen, or otherwise misused account, followed by viewing, stealing, modifying information, or performing unauthorized actions.
Impact	Data exposure, fraud, unauthorized alteration, financial loss, regulatory consequences, investigation difficulties, and reputational damage.
Risk	High. Account control weaknesses make misuse plausible, while compromise of banking systems or customer data can have serious financial and regulatory consequences. The final numerical score should use the group's agreed risk matrix.

3. Individual Technology proposal A – VPN

Candidate: OpenVPN Access Server

1. Northbridge problem

Northbridge currently allows remote and travelling staff, including two IT contractors, to access the network through a shared VPN account without multi factor authentication. This creates weak accountability because multiple users may use the same credentials, and compromise of the shared account could provide unauthorized remote access.

2. Selected technology

The proposed VPN solution is OpenVPN Access Server.

3. How it works

OpenVPN Access Server provides secure remote access VPN connectivity between authorized users and the organization's internal network. Instead of using one shared VPN account, individual user accounts can be used. It can integrate with RADIUS authentication and MFA mechanisms. In the proposed Northbridge architecture, OpenVPN would work with the centralized authentication service so that remote access authentication can be managed more consistently.

4. Why it fits Northbridge

It directly addresses Northbridge's shared VPN account problem by supporting individual authentication and centralized access control. Separate accounts improve accountability for remote employees and contractors, while MFA can provide additional protection if a password is compromised. User access policies can also limit which internal resources different remote users are permitted to reach.

5. Serious alternative considered

A credible alternative is Cisco Secure Client with a compatible Cisco VPN/firewall platform.

6. Direct comparison

Both solutions can provide encrypted remote access, individual authentication and integration with enterprise authentication systems. Cisco's solution is particularly attractive in an organization already using a wider Cisco security ecosystem because VPN, firewall and identity technologies can be closely integrated. OpenVPN Access Server is more platform independent and fits the proposed Member 4 architecture without requiring Northbridge to adopt a predominantly Cisco security environment.

7. Limitation

OpenVPN Access Server still requires careful server administration, patching, certificate management, account lifecycle management, logging, endpoint configuration and capacity planning. Deploying OpenVPN therefore does not by itself solve all remote access security problems.

8. Final justification

OpenVPN Access Server is recommended because it provides a practical way to replace Northbridge's shared VPN account with individually authenticated remote access and can integrate with the proposed FreeRADIUS service. MFA should also be required for

remote users. This combination directly improves authentication and accountability for Northbridge's remote staff and contractors.

4. Individual Technology proposal B – AAA

Candidate: FreeRADIUS

1. Northbridge problem

Northbridge currently relies heavily on local accounts and also has password reuse and sharing weaknesses. This makes centralized access control and accountability difficult, particularly when administrators need to manage access across multiple network services.

2. Selected technology

The proposed AAA technology is FreeRADIUS.

3. How it works

FreeRADIUS implements the RADIUS protocol and can provide centralized Authentication, Authorization and Accounting (AAA). Authentication verifies a user's identity, authorization determines the access that should be provided, and accounting records information about access sessions and authentication activity. Network services such as the proposed VPN can send authentication requests to the RADIUS server instead of independently maintaining shared authentication arrangements.

4. Why it fits Northbridge

Centralized AAA would improve Northbridge's ability to control individual access and maintain authentication records. It is particularly useful alongside OpenVPN Access Server because the VPN service can use RADIUS for centralized authentication. Accounting information can also contribute to improved auditing and investigation.

5. Serious alternative considered

A credible alternative is Cisco Identity Services Engine.

6. Direct comparison

FreeRADIUS provides the core RADIUS/AAA functionality required for centralized authentication and is flexible across different platforms. Cisco ISE provides a broader enterprise identity and network access control platform, including capabilities such as policy based network access, profiling and other NAC functionality. ISE may therefore be more suitable where Northbridge requires a comprehensive Cisco centered NAC deployment, while FreeRADIUS is a more focused option for the proposed vendor neutral architecture.

7. Limitation

FreeRADIUS is not a complete identity security-monitoring solution. It requires proper integration with user directories, network devices and applications, and administrators need sufficient expertise to securely configure and maintain it. Availability and redundancy would also need to be designed for a production banking environment.

8. Final justification

FreeRADIUS is recommended because it provides centralized AAA capabilities that directly address Northbridge's decentralized authentication weaknesses and can integrate with the proposed OpenVPN solution. It should form part of a wider identity architecture that includes individual accounts, strong password policies, MFA where appropriate and centralized logging.

5. Individual Technology proposal C – Secure Architecture

Candidate: OPNsense Multi-Firewall and VLAN Architecture

1. Northbridge problem

Northbridge currently operates a largely flat network and does not have a dedicated firewall architecture separating systems according to their security requirements. This is particularly concerning because the organization operates a public online banking service, core banking systems, staff networks, branch connectivity, remote access services and third-party/payment processor connections.

2. Selected technology

The proposed solution is an OPNsense based multi firewall and VLAN/security zone architecture.

3. How it works

The architecture divides the network into separate security zones rather than allowing systems to communicate freely across one flat network. OPNsense firewalls enforce rules between these zones. A possible Northbridge design would separate the public/DMZ environment, core banking systems, employee network, management systems, branches, VPN users, guest/BYOD devices and third-party connections. Firewall rules would then allow only explicitly required communication between zones.

4. Why it fits Northbridge

Segmentation is particularly important for Northbridge because compromise of one lower trust system should not automatically provide unrestricted access to critical banking systems. Public-facing banking services can be isolated from internal systems, while payment processors and remote users can be given only the network access necessary for

their roles. This directly supports the security requirements identified in T1 - Online Banking Portal Compromise.

5. Serious alternative considered

A credible alternative is a Palo Alto Networks PA-Series firewall architecture.

6. Direct comparison

Both approaches can enforce security zones and inter-zone firewall policies. Palo Alto provides a highly integrated commercial enterprise security platform with centralized management and advanced security capabilities available within its ecosystem. OPNsense provides a flexible standards based firewall platform that can support VLANs, zones, routing and firewall policies without requiring Northbridge to standardize on the Palo Alto ecosystem.

7. Limitation

Using OPNsense does not automatically make the architecture secure. Northbridge would still require correct firewall rule design, appropriate hardware sizing, high availability, patching, configuration backups, monitoring and skilled administrators. Incorrectly designed inter-zone rules could undermine the benefits of segmentation.

8. Final justification

An OPNsense based segmented architecture is recommended because it directly addresses Northbridge's flat network weakness while allowing separate trust boundaries to be created around critical systems. It should be deployed as part of a layered architecture with multiple security zones, restrictive inter-zone rules, IDS/IPS monitoring and centralized logging.

6. Individual Technology proposal D – IDS/IPS

Candidate: Suricata IDS/IPS

1. Northbridge requirement/problem

Northbridge currently has no dedicated IDS/IPS capability and lacks centralized security monitoring. This reduces its ability to identify suspicious network activity and detect attacks against public-facing or internal systems.

2. Selected technology

The proposed IDS/IPS technology is Suricata.

3. How it works

Suricata is an open source network intrusion detection and prevention engine. It analyzes network traffic using signatures, protocol analysis and other detection capabilities. In IDS mode, it can monitor traffic and generate alerts without directly blocking it. When appropriately deployed inline as an IPS, it can also take preventive action against traffic matching configured detection rules.

4. Why it fits Northbridge

Suricata sensors could be positioned at important network boundaries such as the Internet/DMZ boundary and selected internal segments. This would improve visibility into attacks against Northbridge's public services and suspicious communication attempting to cross sensitive network boundaries. Its event output can also be forwarded to centralized logging and monitoring systems.

5. Serious alternative considered

A credible alternative is Snort 3.

6. Direct comparison

Both Suricata and Snort are established intrusion-detection/prevention technologies and support signature-based network analysis. Snort has a mature rule ecosystem and is particularly attractive where an organization is using Cisco security technologies. Suricata provides strong multi threaded processing, protocol analysis and structured event output, making it suitable for the vendor-neutral architecture proposed here.

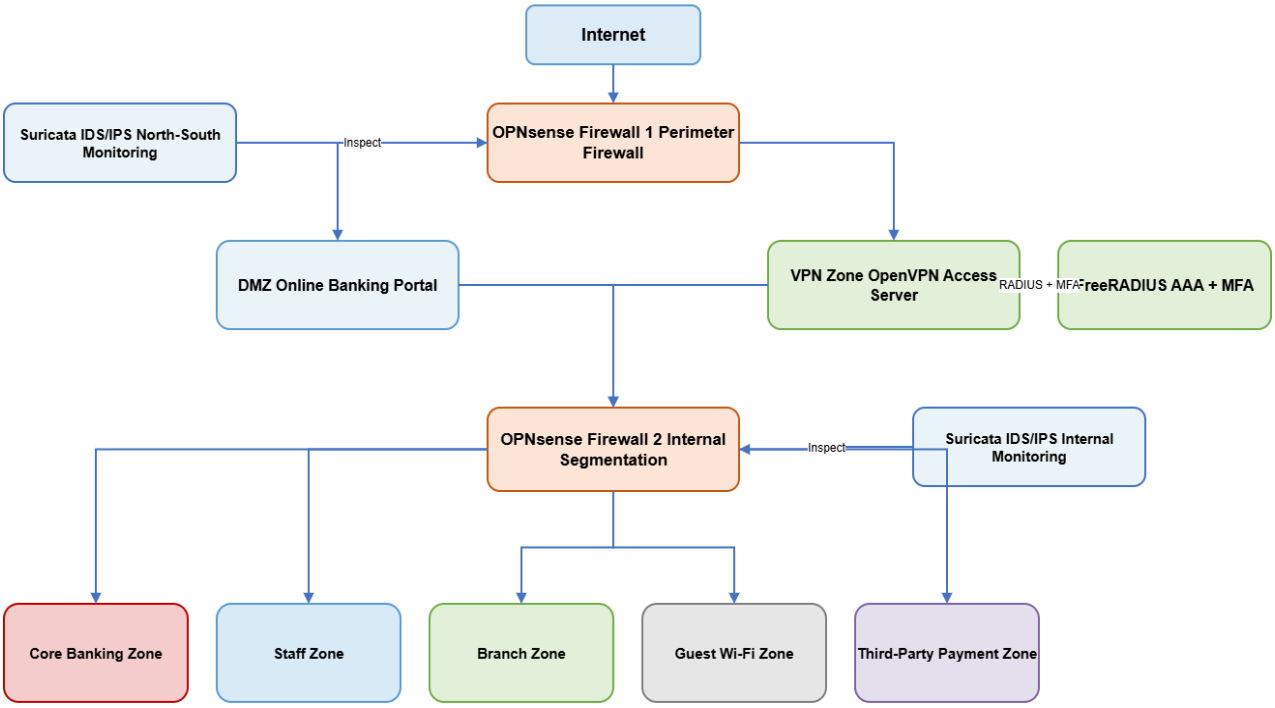
7. Limitation

Suricata requires continuous rule maintenance and tuning. Poorly tuned rules can produce false positives, while no IDS/IPS can guarantee detection of every attack. Encrypted traffic can also limit payload visibility, and sensor placement and hardware capacity affect performance. Alerts must therefore be integrated into an actual monitoring and incident response process.

8. Final justification

Suricata is recommended because it adds the network detection capability currently missing from Northbridge and complements the proposed segmented firewall architecture. Northbridge could initially deploy it in IDS mode to establish visibility and tune detection rules before selectively introducing inline IPS enforcement where the operational risk is acceptable.

- **Proposed Architecture**



7. Individual Technology proposal D – IDS/IPS

Zone-Based Firewall

Objective

Implement zone-based traffic control between an INSIDE client network and an OUTSIDE server network. HTTP and HTTPS are classified for stateful inspection from INSIDE to OUTSIDE, while the class default action is configured to drop unmatched traffic. This demonstrates a firewall control relevant to T1.

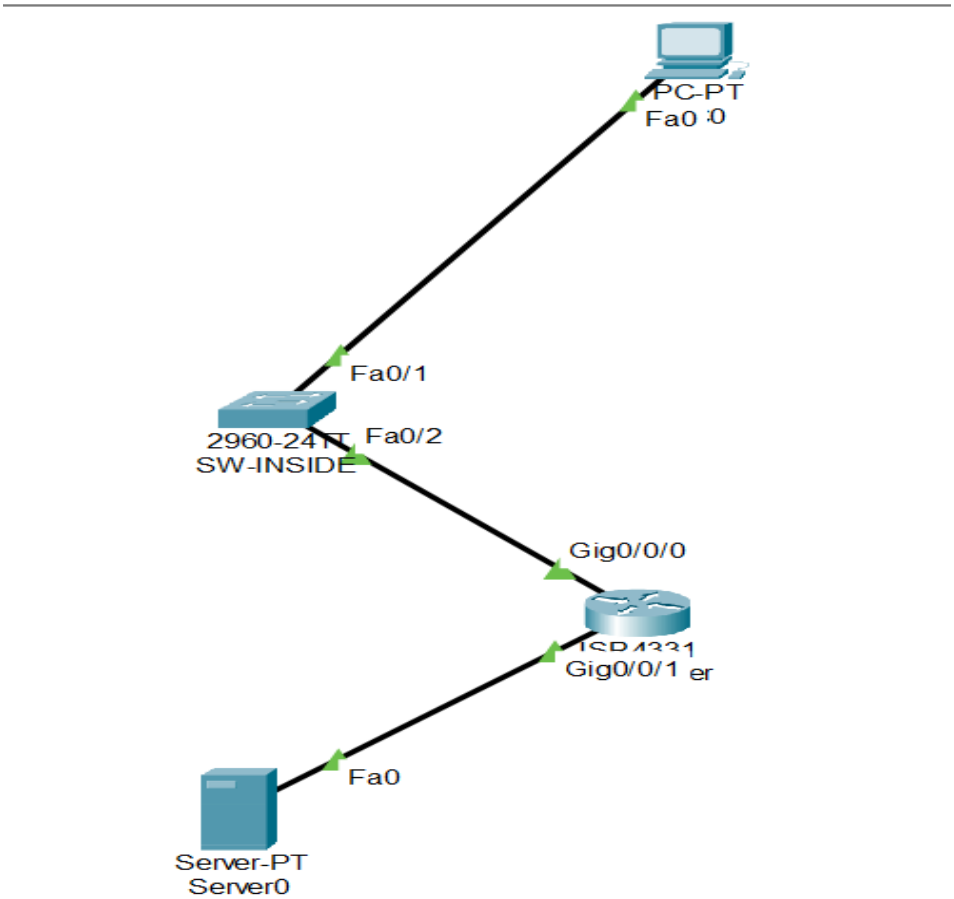


Figure 1. Representative Cisco Packet Tracer topology for the ZBF demonstration.

Device / interface	Address	Role
PC0	192.168.10.10/24; GW 192.168.10.1	INSIDE client
Router G0/0/0	192.168.10.1/24	INSIDE interface
Router G0/0/1	203.0.113.1/24	OUTSIDE interface
Server0	203.0.113.2/24; GW 203.0.113.1	Web server

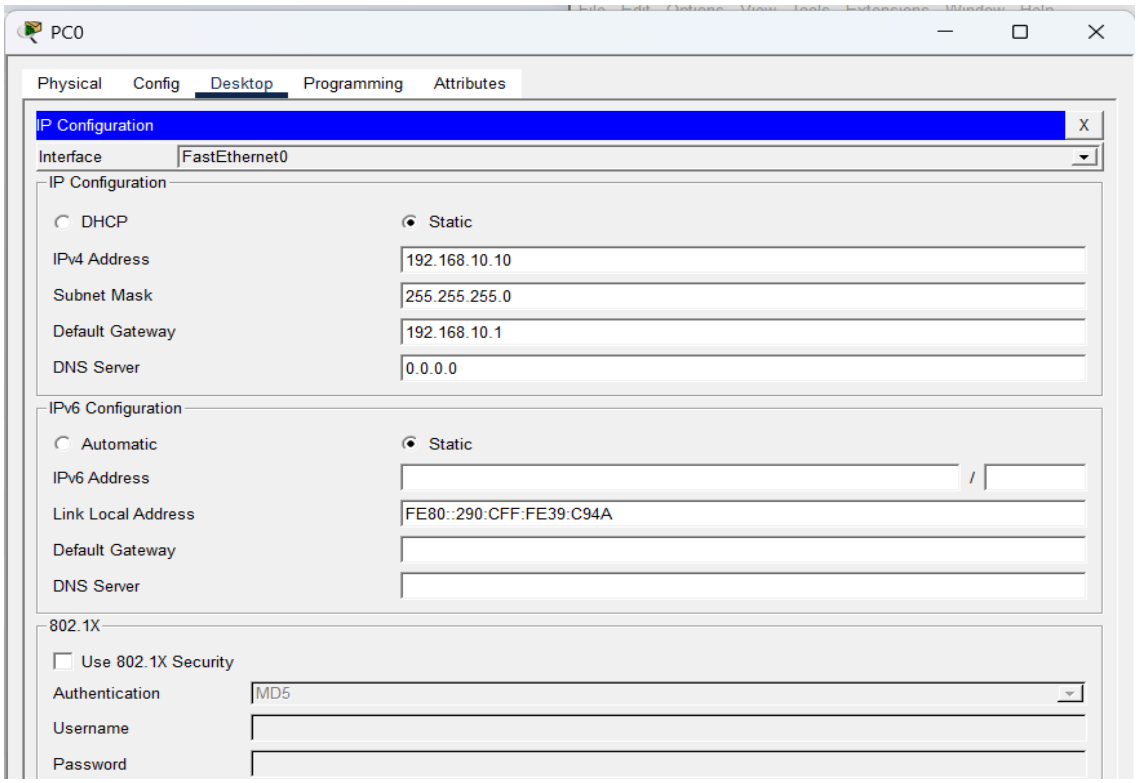


Figure 2. PC0 IPv4 configuration.

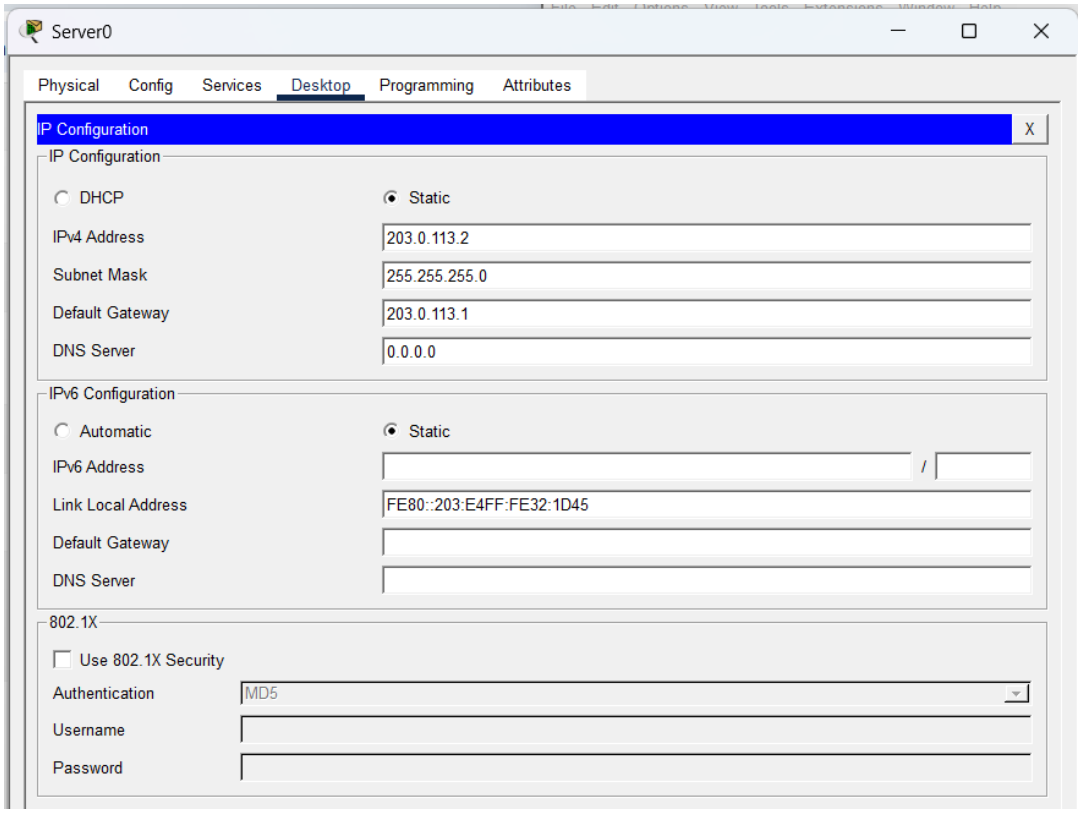


Figure 3. Server0 IPv4 configuration.

- **Configuration commands**

```
enable
configure terminal
hostname ZBF-Router
zone security INSIDE
zone security OUTSIDE
!
interface GigabitEthernet0/0/0
 ip address 192.168.10.1 255.255.255.0
 zone-member security INSIDE
 no shutdown
exit
!
interface GigabitEthernet0/0/1
 ip address 203.0.113.1 255.255.255.0
 zone-member security OUTSIDE
 no shutdown
exit
!
class-map type inspect match-any CM-WEB-TRAFFIC
 match protocol http
 match protocol https
exit
!
policy-map type inspect PM-INSIDE-TO-OUTSIDE
 class type inspect CM-WEB-TRAFFIC
  inspect
 exit
 class type inspect class-default
  drop
 exit
exit
```

!

zone-pair security ZP-INSIDE-OUTSIDE source INSIDE destination OUTSIDE

service-policy type inspect PM-INSIDE-TO-OUTSIDE

exit

end

copy running-config startup-config

- ## Command and verify evidence

  The final interface and zone output verifies that the router interfaces are operational and assigned to the intended security zones.

```
ZBF-Router>
ZBF-Router>show ip interface brief
Interface              IP-Address      OK? Method Status                Protocol
GigabitEthernet0/0/0   192.168.10.1    YES manual up                    up
GigabitEthernet0/0/1   203.0.113.1     YES manual up                    up
GigabitEthernet0/0/2   unassigned      YES unset  administratively down down
Vlan1                  unassigned      YES unset  administratively down down
ZBF-Router>enable
ZBF-Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
ZBF-Router(config)#interface GigabitEthernet0/0/0
ZBF-Router(config-if)#zone-member security INSIDE
ZBF-Router(config-if)#exit
ZBF-Router(config)#interface GigabitEthernet0/0/1
ZBF-Router(config-if)#zone-member security OUTSIDE
ZBF-Router(config-if)#exit
ZBF-Router(config)#do show zone security
zone self
  Description: System defined zone


zone INSIDE
  Member Interfaces:
    GigabitEthernet0/0/0


zone OUTSIDE
  Member Interfaces:
    GigabitEthernet0/0/1


ZBF-Router(config)#do show zone-pair security
ZBF-Router(config)#
```

Figure 4. Interface status and verification of INSIDE/OUTSIDE zone membership.

```
ZBF-Router>enable
ZBF-Router#
ZBF-Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
ZBF-Router(config)#class-map type inspect match-any CM-WEB-TRAFFIC
ZBF-Router(config-cmap)#match protocol http
ZBF-Router(config-cmap)#match protocol https
ZBF-Router(config-cmap)#
```

Figure 5. CM-WEB-TRAFFIC class-map configuration for HTTP and HTTPS.

The following running configuration evidence verifies the final class map, policy map, default drop action, zone pair, and service policy association.

```
ZBF-Router(config)#
ZBF-Router(config)#policy-map type inspect PM-INSIDE-TO-OUTSIDE
ZBF-Router(config-pmap)#class class-default
ZBF-Router(config-pmap-c)#drop
ZBF-Router(config-pmap-c)#exit
ZBF-Router(config-pmap)#exit
ZBF-Router(config)#zone-pair security ZP-INSIDE-OUTSIDE source INSIDE destination OUTSIDE
ZBF-Router(config-sec-zone-pair)#service-policy type inspect PM-INSIDE-TO-OUTSIDE
ZBF-Router(config-sec-zone-pair)#exit
ZBF-Router(config)#do show zone-pair security
Zone-pair name ZP-INSIDE-OUTSIDE
    Source-Zone INSIDE  Destination-Zone OUTSIDE
    service-policy PM-INSIDE-TO-OUTSIDE

ZBF-Router(config)#
```

Figure 6. Zone-pair creation and service policy application.

```
!
class-map type inspect match-any CM-WEB-TRAFFIC
 match protocol http
 match protocol https
!
policy-map type inspect PM-INSIDE-TO-OUTSIDE
 class type inspect CM-WEB-TRAFFIC
  inspect
 class type inspect class-default
  drop
!
!
!
```

Figure 7. Final class map and policy map configuration.

```
!
zone security INSIDE
zone security OUTSIDE
zone-pair security ZP-INSIDE-OUTSIDE source INSIDE destination OUTSIDE
 service-policy type inspect PM-INSIDE-TO-OUTSIDE
!
!
```

Figure 8. Final zone and zone-pair configuration.

```
interface GigabitEthernet0/0/0
 ip address 192.168.10.1 255.255.255.0
 zone-member security INSIDE
 duplex auto
 speed auto
!
interface GigabitEthernet0/0/1
 ip address 203.0.113.1 255.255.255.0
 zone-member security OUTSIDE
 duplex auto
 speed auto
!
```

Figure 9. Final interface addressing and zone membership.

- ## Functional verification

  After the policy was applied, the ICMP test from PC0 to 203.0.113.2 received no replies, while HTTP access to the same server remained successful. The failed ping is functional evidence consistent with the configured policy, it is not used alone as proof that the firewall generated the drop, because server side ICMP behaviour can also affect ping results.

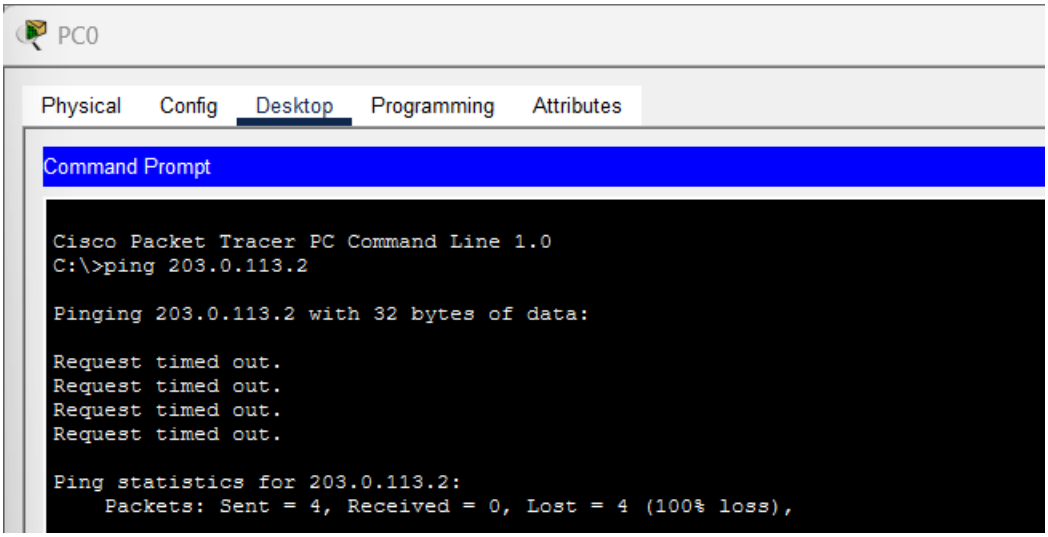


Figure 11. ICMP functional test: four requests timed out (100% loss).

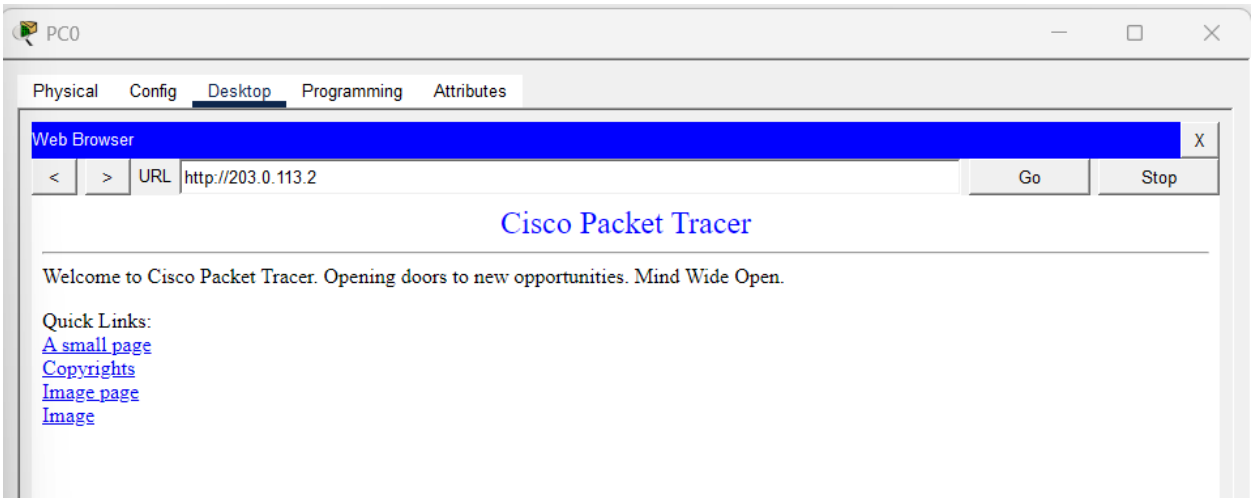


Figure 12. HTTP functional test: PC0 successfully accesses the web server at 203.0.113.2.

PC0 in the INSIDE zone successfully accesses the web server at 203.0.113.2 in the OUTSIDE zone. HTTP traffic is matched by the CM-WEB-TRAFFIC class-map and inspected by the PM-INSIDE-TO-OUTSIDE policy.

```
ZBF-Router>enable
ZBF-Router#show policy-map type inspect zone-pair sessions

policy exists on zp ZP-INSIDE-OUTSIDE
 Zone-pair: ZP-INSIDE-OUTSIDE

  Service-policy inspect : PM-INSIDE-TO-OUTSIDE

    Class-map: CM-WEB-TRAFFIC (match-any)
      Match: protocol http
        16 packets, 659 bytes
        30 second rate 0 bps
      Match: protocol https
        0 packets, 0 bytes
        30 second rate 0 bps
      Inspect


    Class-map: class-default (match-any)
      Match: any
      Drop
        0 packets, 0 bytes

ZBF-Router#
```

Figure 13. ZBF policy verification showing HTTP packets matched and inspected.

```
ZBF-Router#copy running-config startup-config
Destination filename [startup-config]?
Building configuration...
[OK]
ZBF-Router#
```

Figure 14. Configuration saved to startup-config.

- **Result and security relevance**

  The ZBF configuration successfully demonstrates security-zone separation and policy based traffic control. HTTP traffic from INSIDE to OUTSIDE was matched by CM-WEB-TRAFFIC and inspected, while the policy includes a default drop action for unmatched traffic. This supports T1 by illustrating how explicit firewall policy can reduce unnecessary exposure between security zones. In the Northbridge production design, this would be only one layer of the larger DMZ, multi firewall, segmented architecture and would be combined with patch management, IDS/IPS, centralized logging, secure administration, and other controls.

8. Network Hardening Configuration 2

PortFast +BPDU Guard

Objective

Configure an endpoint facing access port with PortFast and BPDU Guard. PortFast allows the edge port to transition quickly to forwarding, while BPDU Guard protects the port by placing it into an err-disabled state if a BPDU is unexpectedly received. This helps prevent an unauthorized or incorrectly connected switch from influencing the Spanning Tree topology through that edge port.

.

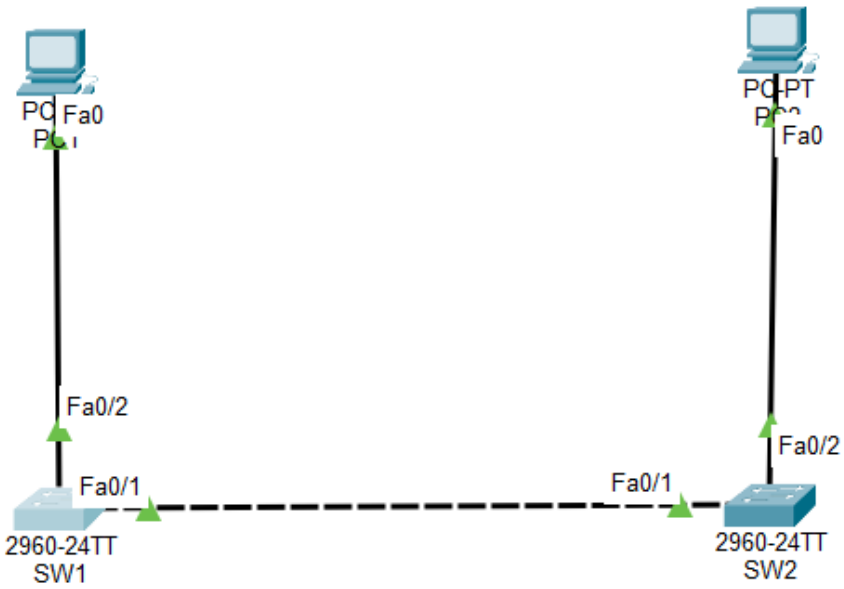


Figure 15. Baseline Packet Tracer topology: PC1 - SW1 - SW2 - PC2.

baseline connectivity evidence before applying the hardening configuration.

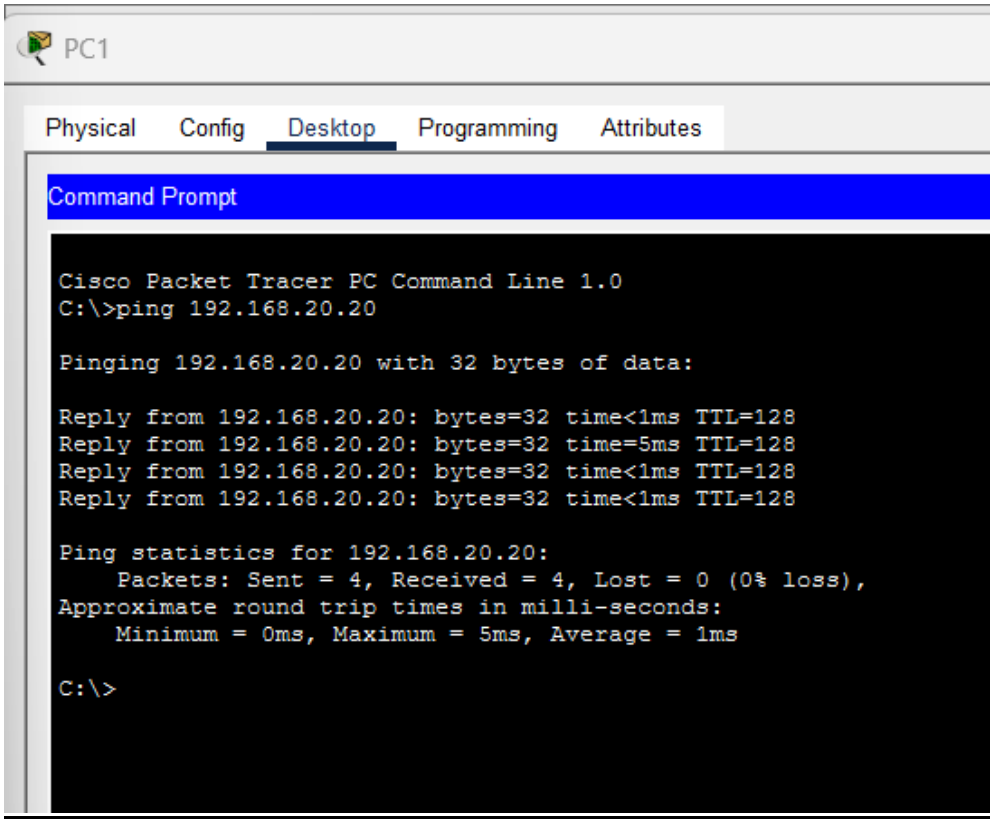


Figure 16. Baseline PC1-to-PC2 ping: four replies, 0% loss.

- **Configuration commands**

```
enable
configure terminal
hostname SW1
interface FastEthernet0/2
 switchport mode access
 spanning-tree portfast
 spanning-tree bpduguard enable
exit
end
```

```
!
interface FastEthernet0/1
!
interface FastEthernet0/2
 switchport mode access
 spanning-tree portfast
 spanning-tree bpduguard enable
!
```

Figure 17. SW1 FastEthernet0/2 configured as an access port with PortFast and BPDU Guard.

- **Deliberate BPDU Guard test**

  For the test, the endpoint connection on SW1 FastEthernet0/2 was replaced with a connection to TEST-SW. This deliberately caused the protected edge port to receive a BPDU.

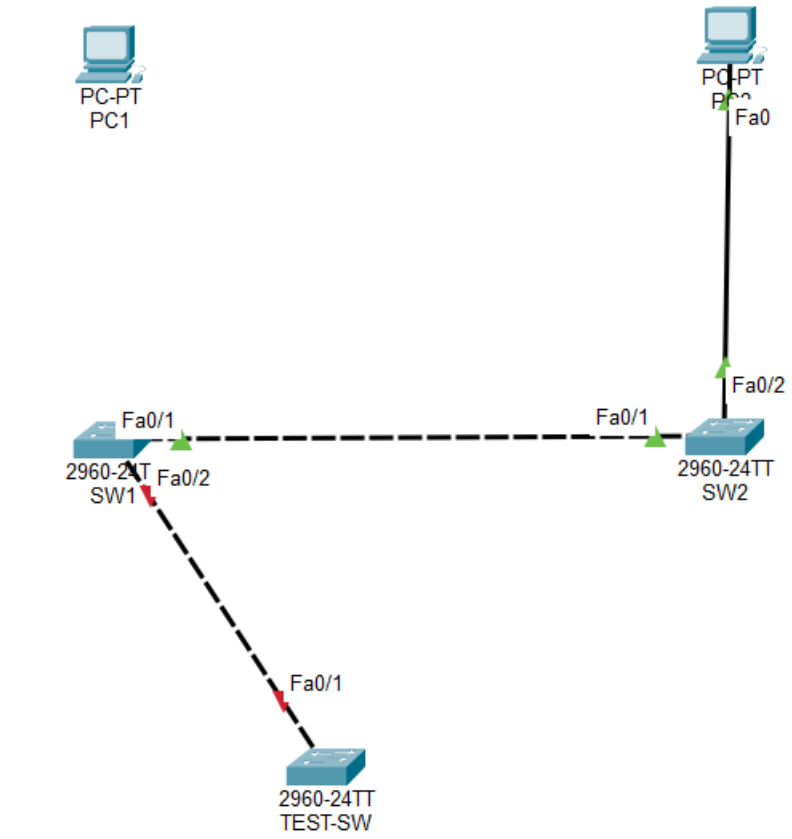


Figure 18. TEST-SW connected to the protected SW1 FastEthernet0/2 access port.

SW1 generated a BPDU Guard message indicating that a BPDU had been received on FastEthernet0/2 and that the port was being disabled.

```
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/2, changed state to up
%SPANTREE-2-BLOCK_BPDUGUARD: Received BPDU on port FastEthernet0/2 with BPDU Guard enabled. Disabling port.
```

Figure 19. BPDU Guard event message showing FastEthernet0/2 being disabled.

- **Verification**

show interfaces status

show interfaces FastEthernet0/2

The interface status output verifies that Fa0/2 entered the err-disabled state after the BPDU Guard violation.

```
SW1>enable
SW1#show interfaces status
Port      Name               Status       Vlan       Duplex  Speed Type
Fa0/1                        connected    1          a-full  a-100 10/100BaseTX
Fa0/2                        err-disabled 1          auto    auto  10/100BaseTX
Fa0/3                        notconnect   1          auto    auto  10/100BaseTX
```

Figure 20. show interfaces status verification: Fa0/2 is err-disabled.

```
SW1#
SW1#show spanning-tree interface FastEthernet0/2 detail

SW1#show interfaces FastEthernet0/2
FastEthernet0/2 is down, line protocol is down (err-disabled)
  Hardware is Lance, address is 0002.1689.4d02 (bia 0002.1689.4d02)
```

Figure 21. Interface verification showing FastEthernet0/2 down / err-disabled.

- **Recovery procedure**

  After removing the unexpected switch connection and reconnecting the intended endpoint, the interface can be manually recovered after confirming the cause of the

  violation.
  enable
  configure terminal
  interface FastEthernet0/2
  shutdown
  no shutdown
  end

- **Result and security relevance**

  The test successfully demonstrated BPDU Guard operation. Under normal conditions, PC1 and PC2 had connectivity. When TEST-SW was deliberately connected to the protected edge port, SW1 received a BPDU and disabled FastEthernet0/2. Verification then showed the interface in the err-disabled state. BPDU Guard therefore provides a useful protection for endpoint-facing ports against unexpected switch connections and

Spanning Tree participation. It does not block every rogue device or every Layer 2 attack, so it should be combined with wider switch-port and access-control hardening.

- # References

OpenVPN Access Server - Authentication Systems: https://openvpn.net/access-server/features/authentication-systems/

OpenVPN Access Server - RADIUS: https://openvpn.net/as-docs/radius.html

OpenVPN Access Server - Access Control: https://openvpn.net/access-server/features/access-control/

Cisco VPN / Secure Client information:
https://www.cisco.com/site/us/en/products/security/vpn/index.html

FreeRADIUS - AAA concepts: https://www.freeradius.org/documentation/freeradius-server/3.2.11/concepts/aaa.html

FreeRADIUS documentation: https://doc.freeradius.org/

OPNsense - Security Zones: https://docs.opnsense.org/manual/how-tos/security-zones.html

OPNsense - VLAN and LAGG: https://docs.opnsense.org/manual/how-tos/vlan_and_lagg.html

Suricata - Features: https://suricata.io/features/all-features/

Snort 3: https://snort.org/snort3